

Silvia Sisinni

silvia.sisinni@polito.it



Module A – Cybersecurity Fundamentals

A6 - Adversary Behavior and Defensive Mapping



**Politecnico
di Torino**

Department of Control and
Computer Engineering



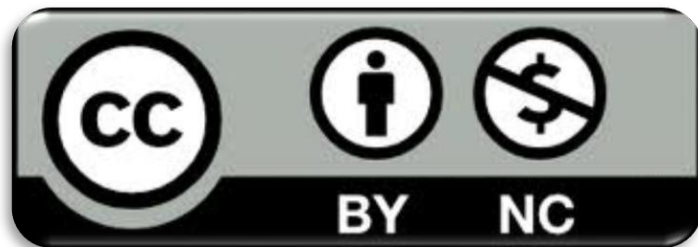
TORSEC

Computer and Network Security Group

License & Disclaimer

License Information

This presentation is licensed under the
Creative Commons BY-NC License



To view a copy of the license, visit:

<http://creativecommons.org/licenses/by-nc/3.0/legalcode>

Disclaimer

- We disclaim any warranties or representations as to the accuracy or completeness of this material.
- Materials are provided “as is” without warranty of any kind, either express or implied, including without limitation, warranties of merchantability, fitness for a particular purpose, and non-infringement.
- Under no circumstances shall we be liable for any loss, damage, liability or expense incurred or suffered which is claimed to have resulted from use of this material.
- This material is used and adapted within the course “Cybersecurity and National Defense”.



Learning goals

By the end of this lecture, students should be able to:

1. **Explain why sequential attack models are often insufficient** to describe real adversary behavior.
2. **Interpret MITRE ATT&CK as a behavioral framework**, distinguishing:
 - tactics as adversary objectives
 - techniques as reusable methods
 - procedures as campaign-specific implementations
3. **Map an observed intrusion path to ATT&CK techniques** in a way that supports defensive reasoning.
4. **Analyze Stuxnet as a cyber-physical campaign** using both:
 - Kill Chain for structural progression
 - ATT&CK for detailed behavioral analysis.



Roadmap



- **From sequential models to behavioral ontologies**
- Introducing MITRE ATT&CK
- Defensive Mapping
- Case Study: Stuxnet



How do we systematically describe an adversary?

- Cyber defense requires a structured description of attack behavior.
- To defend effectively, we must answer three distinct questions:

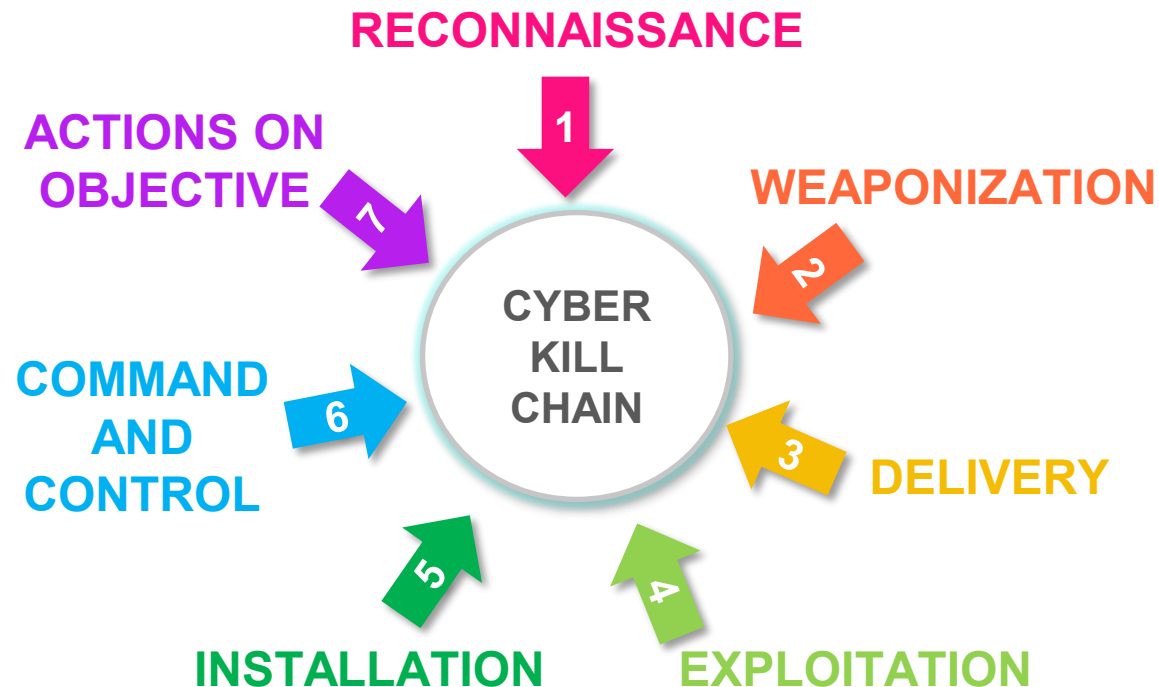
What objective is the adversary pursuing?

What technique is being used?

What observable evidence does this behavior
produce?

Recap: What the Cyber Kill Chain gives us

- The Cyber Kill Chain models intrusions as a **sequence of stages**.
- It is useful because it helps defenders reason about:
 - attack progression
 - possible interruption points
 - where controls may stop or slow the attacker
- But it has an important limitation:
 - it assumes a relatively **linear view of intrusion development**





Why sequential models are not enough

- Real-world adversaries do not always follow a clean linear path.
- They often:
 - pivot between hosts,
 - repeat steps
 - retry failed actions,
 - reuse the same technique in different contexts,
 - combine human and technical actions opportunistically.
- A defender may therefore observe:
 - credential theft before obvious malware installation,
 - lateral movement without a clear exploit phase,
 - persistence re-established after containment,
 - multiple techniques serving the same tactical goal.
- So if defense is to be measurable, it must be expressed in terms of **observable behavior**, not only in terms of phases.





A conceptual shift

Cyber Kill Chain asks:

“Where are we in the intrusion sequence?”

This is useful for:

- progression,
- interruption,
- campaign structure.

Behavioral frameworks ask:

“What is the adversary doing?”

This is useful for:

- detection engineering,
- telemetry design,
- capability assessment,
- threat-informed defense.



Defense engineering requires the second question, not only the first.



Roadmap



- From sequential models to behavioral ontologies ✓
- **Introducing MITRE ATT&CK**
- Defensive Mapping
- Case Study: Stuxnet



What MITRE ATT&CK is - and what it is not



- MITRE ATT&CK is a curated, continuously updated knowledge base of **real-world adversary behavior**.
- It is built from documented observations of intrusion campaigns and operational tradecraft.
- ATT&CK does **not** primarily catalog:
 - malware families,
 - vulnerabilities,
 - specific tools.
- Instead, it catalogs **behavioral patterns** used by adversaries.
- ATT&CK organizes that behavior at three levels:
 - **Tactics** = why the action is performed
 - **Techniques** = how the objective is achieved
 - **Procedures** = how a technique is concretely implemented in a specific campaign





ATT&CK is not another Kill Chain

ATT&CK is not a fixed attack sequence.

It does not say: first do A, then do B, then do C.

Instead, it provides a **behavioral space**:

- multiple techniques can support the same tactic;
- the same technique can appear in very different campaigns;
- attackers can move through the matrix in many different ways.

Example: for **Credential Access**, an adversary might use:

- brute force
- Phishing
- credential dumping
- password store access
- adversary-in-the-middle

Same objective, different behaviors.

ATT&CK matrix overview

Tactics (adversary objectives)

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion
11 techniques	8 tech.	11 tech.	17 tech.	23 tech.	14 tech.	47 tech.
Active Scanning	Acquire Access	Content Injection	Cloud Admin Command	Ac Ma	Abuse	Abuse Elevation Control Mechanisms
Gather Victim Host Information	Acquire Infrastructure	Drive-by Compromise	Deploy Container	BIT	Manipulation	Access Token Manipulation
Gather Victim Network Information	Compromise Accounts	HW Additions	Input Injection	Cloud Application Integration	Account Manipulation	BITS Jobs
Gather Victim Org Information	Develop Capabilities	Phishing	Native API	Create Account	Escape to Host	Build Image on Host
...	...	...	...	...	...	...

Techniques (methods used to achieve the objective)



ATT&CK matrix overview

Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
17 techniques	34 tech.	9 tech.	17 tech.	18 tech.	9 tech.	15 tech.
Adversary-in-the-Middle	Account Discovery	Exploitation of Remote Services	Adversary-in-the-Middle	Application Layer Protocol	Automated Exfiltration	Account Access Removal
Brute Force	Application Window Discovery	Internal Spearphishing	Archive Collected Data	Content Injection	Data Transfer Size Limits	Data Destruction
Credentials from Password Stores	Browser Information Discovery	Lateral Tool Transfer	Audio Capture	Data Encoding	Exfiltration Over Alternative Protocol	Data Encrypted for Impact
Exploitation for Credential Access	Cloud Infrastructure Discovery	Remote Services	Automated Collection	Data Obfuscation	Exfiltration Over C2 Channel	Data Manipulation
..	 Analyst workflow: observe behavior → map to technique → infer objective					



How to read the ATT&CK matrix

1. Columns = Tactics

This represent adversary objectives

2. Cells = Techniques

These are general behavioral methods used to achieve those objectives

3. Sub-techniques = finer-grained operational variants

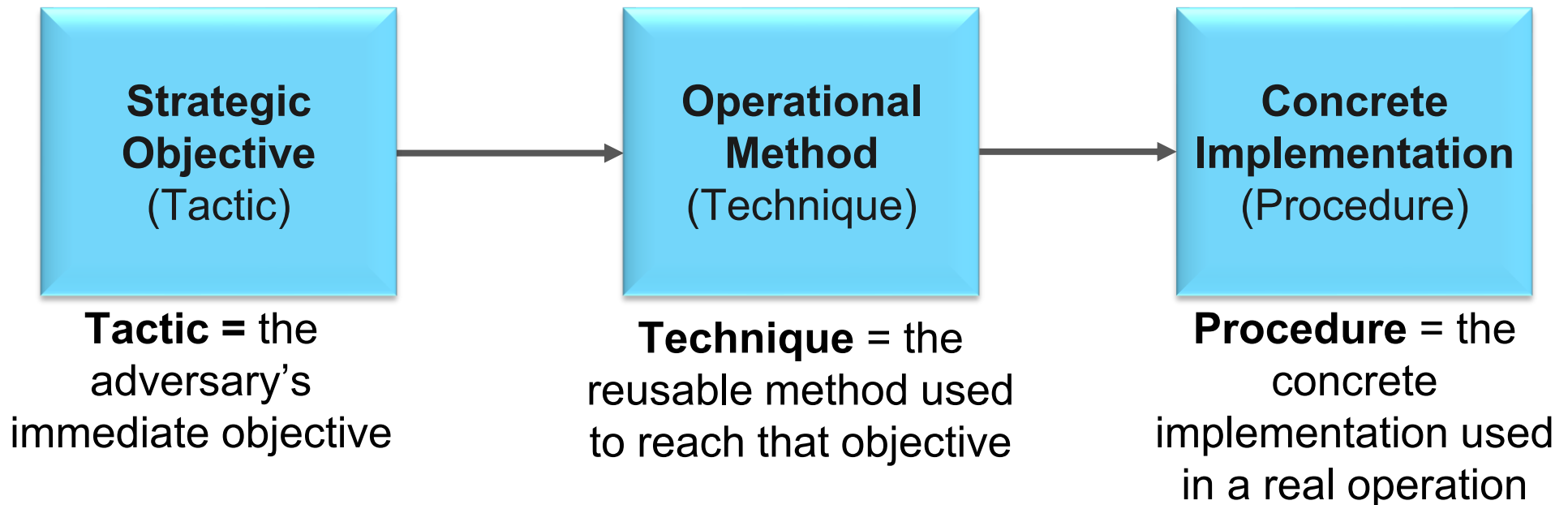
These make analysis more specific and more useful for detection.

- Read columns as goals. Select techniques based on observed behavior.

Important:

- ATT&CK is not read left-to-right as a mandatory sequence.
- Analysts select techniques based on **observed behavior**, not on abstract campaign phases.

Tactic, Technique, Procedure: three analytical levels

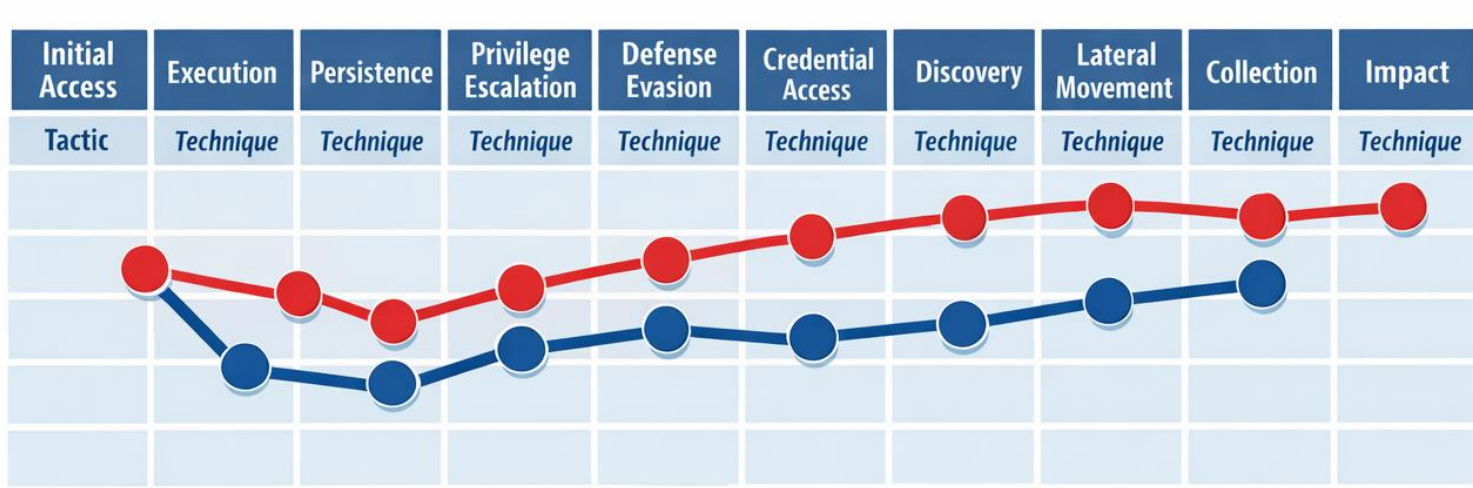


Example:

- Tactic: Credential Access
- Technique: OS Credential Dumping
- Procedure: dumping LSASS memory with a specific tool

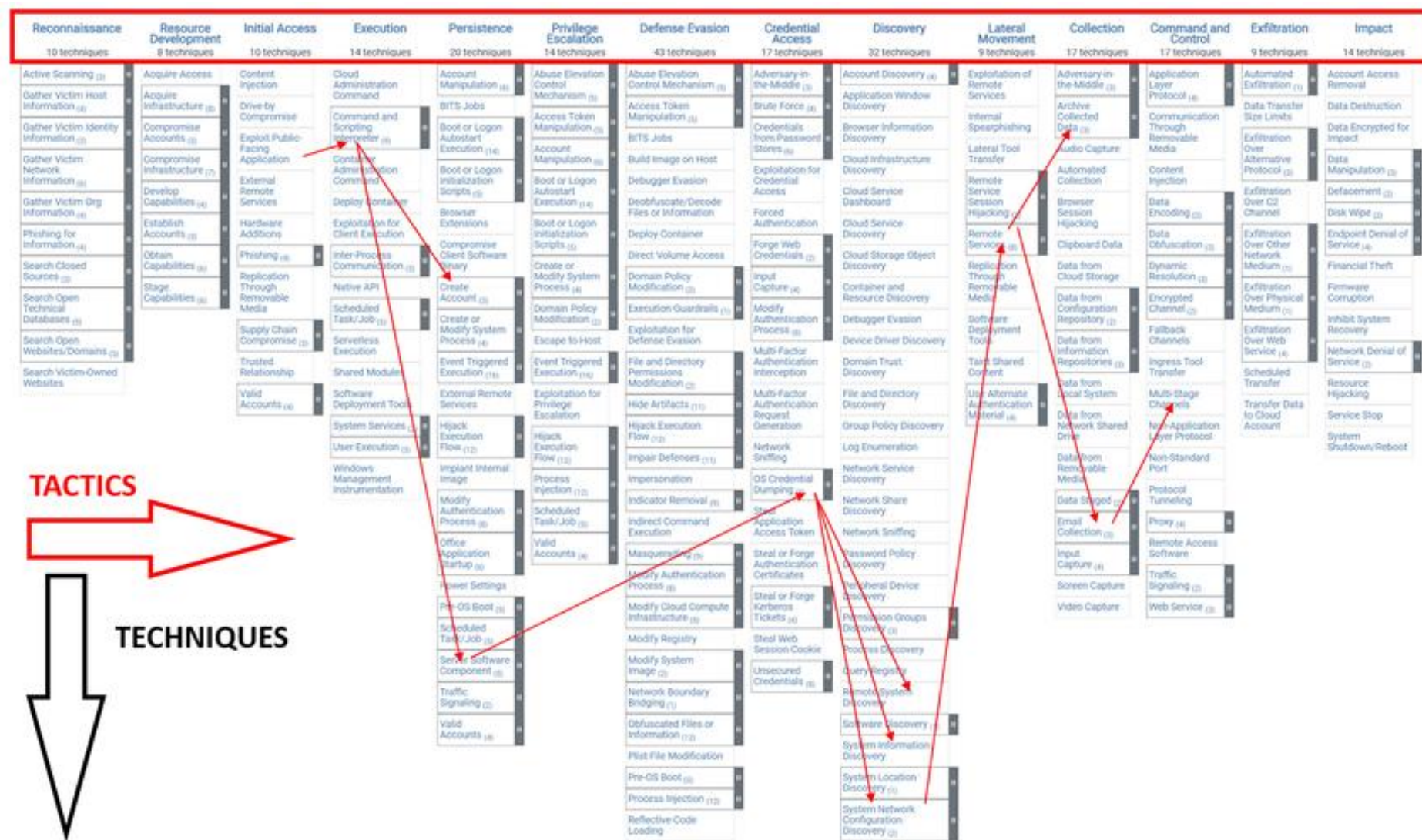
The ATT&CK as a behavioral search space

- The ATT&CK matrix can be interpreted as a multidimensional space of adversary behavior.
- This means:
 - an attack can be modeled as a **path** through tactics and techniques;
 - different adversaries may follow different paths toward similar objectives;
 - different campaigns may overlap behaviorally without being the same campaign.
- Therefore: behavioral overlap is informative, but it is **not enough** by itself for attribution.





The ATT&CK Matrix as Behavioral Space





Example: one intrusion path through ATT&CK

Scenario: A phishing email tricks a user into running malware. The attacker gains a foothold, may establish persistence, may escalate privileges, may steal credentials, may move to other systems, and may exfiltrate data. This is only one possible path through ATT&CK techniques.

ATT&CK tactic	Example technique	What it means
Initial Access	Phishing	The attacker gains the first foothold by deceiving a user
Execution	User Execution	Malicious code runs because the user opens the file or link
Persistence	Scheduled Task / Registry Run Key	Malware is configured to start again automatically
Privilege Escalation	Exploitation for Privilege Escalation	The attacker gains higher permissions
Credential Access	OS Credential Dumping	Passwords or authentication secrets are extracted
Lateral Movement	Remote Services / SMB	The attacker uses one compromised machine to reach others
Command and Control	Application Layer Protocol	The malware communicates with the attacker over web-like traffic
Exfiltration	Data Theft	Sensitive data is sent out of the organization



Tactics: adversary objectives



- Tactics represent the adversary's immediate objective at a given point, such as:
 - *Initial Access*
 - *Persistence*
 - *Privilege Escalation*
 - *Lateral Movement*
 - *Command and Control*
 - *Impact*
- *They describe why a behavior is being performed.*

Important:

- tactics are not a strict chronology;
- the same tactic may recur more than once in an operation;
- different techniques may support the same tactic.



Techniques: reusable methods of adversary behavior



- *Techniques describe how adversaries achieve tactical objectives.*
- *A good ATT&CK technique is:*
 - *observable,*
 - *reusable across campaigns,*
 - *not tied to one specific malware family,*
 - *mappable to telemetry and defensive controls.*
- That is why techniques are useful for:
 - detection engineering,
 - coverage analysis,
 - threat-informed defense.

Technique: **OS Credential Dumping**

May appear in very different campaigns, regardless of malware family.



Procedures: campaign-specific implementations



A procedure is the concrete implementation of a technique used in a specific attack campaign.

Examples

➤ Enterprise IT:

- **Tactic:** Credential Access
- **Technique:** OS Credential Dumping
- **Procedure:** Dump LSASS (Local Security Authority Subsystem Service) memory using a specific tool

➤ Industrial Control System (ICS) Context:

- **Tactic:** Initial Access
- **Technique:** Replication Through Removable Media
- **Procedure:** Infected USB introduced into an engineering workstation in an air-gapped environment



Roadmap



- From sequential models to behavioral ontologies ✓
- Introducing MITRE ATT&CK ✓
- **Defensive Mapping**
- Case Study: Stuxnet



A technique is defensible only if it is observable

- A behavioral technique becomes defensible only if:
 - it leaves **artifacts**
 - those artifacts generate **telemetry**
 - the telemetry can be **modeled analytically**
 - the model can support **detection and response**
- So the **defensive chain** is:

Technique → Artifact → Telemetry → Detection Logic → Response

- **Example:**
 - Technique: OS Credential Dumping
 - Artifact: abnormal access to LSASS memory
 - Telemetry: endpoint process monitoring
 - Detection logic: suspicious non-system process reading LSASS
 - Response: **isolate host**, acquire forensic evidence



Artifacts and telemetry



- An **artifact** is a trace left by an action:
 - process creation,
 - registry modification,
 - file change,
 - network connection,
 - authentication event,
 - configuration change.
- **Telemetry** is the mechanism that captures that trace:
 - operating system logs,
 - endpoint sensors,
 - network monitoring,
 - application logs,
 - industrial monitoring data.



Without telemetry, artifacts exist but remain invisible to defenders.



Detection is analytical interpretation



Detection is not mere logging. Detection requires:

- *a behavioral hypothesis,*
- *a baseline of normal activity,*
- *collection of relevant telemetry,*
- *correlation across data sources,*
- *reduction of false positives,*
- *prioritization of operationally meaningful alerts.*

So detection logic answers:

“Given this telemetry, is there enough evidence to infer the presence of a technique?”



Defensive mapping as an analytical workflow



Defensive mapping consists of four analytical steps:

1. **Select relevant techniques**

Which ATT&CK techniques matter for our threat model?

2. **Assess visibility**

What telemetry do we collect that could reveal those techniques?

3. **Assess detection capability**

Do we actually detect them reliably and with acceptable false positives?

4. **Assess mitigation and residual risk**

If detection fails or arrives late, what controls still limit damage?

⇒ **ATT&CK becomes operational only when it is connected to telemetry and control decisions.**



Coverage is not one thing

➤ Coverage must be evaluated along three dimensions:

1. **Visibility coverage**

Do we collect telemetry relevant to the technique?

2. **Detection coverage**

Do we identify the technique with sufficient reliability?

3. **Mitigation coverage**

If the technique succeeds, do we have controls that reduce impact?

⇒ Coverage is therefore not binary. It is a layered measurement of defensive posture.



Detection alone does not eliminate risk

- A technique may be:
 - **visible but not detected**
 - **detected but too late to matter**
 - **detected but not mitigated**
 - **mitigated but still partially exploitable**

- Therefore, defensive maturity requires explicit recognition of:
 - detection limits,
 - response latency,
 - remaining exposure,
 - **residual risk.**



Residual Risk ATT&CK-based defense



Residual risk is the portion of adversary behavior that remains unobserved, undetected, insufficiently mitigated, or still operationally damaging despite controls.

In ATT&CK-based reasoning, residual risk often arises from:

- telemetry blind spots,
- weak analytical coverage,
- delayed response,
- incomplete mitigation,
- attacker adaptation.



Behavioral models and security properties

Each ATT&CK technique ultimately threatens one or more security properties:

- **Confidentiality**

Example: credential dumping, collection, exfiltration

- **Integrity**

Example: controller logic modification, data manipulation

- **Availability**

Example: data destruction, service interruption, sabotage

- **Authenticity / Trustworthiness**

Example: masquerading, malicious commands executed, deceptive reporting



Why ATT&CK matters in national defense

- In national defense and national cyber architectures, ATT&CK supports:
 - **shared operational vocabulary** across agencies and teams
 - **standardized threat reporting**
 - **comparability of defensive posture**
 - **threat-informed capability planning**
 - **cross-organizational coordination** in complex incidents



Roadmap



- From sequential models to behavioral ontologies ✓
- Introducing MITRE ATT&CK ✓
- Defensive Mapping ✓
- **Case Study: Stuxnet**

Stuxnet: a landmark cyber-physical operation

- Discovered in 2010, Stuxnet is the first widely recognized cyber operation that caused **physical sabotage** of industrial equipment through software manipulation.
- It targeted uranium enrichment centrifuges by manipulating Programmable Logic Controller (PLC) logic.
- Stuxnet is not just malware. It is a model case of **integrated IT + OT + physical effects**, with consequences at a strategic/geopolitical level





Stuxnet in one minute: what happened

- **Natanz** was Iran's primary uranium-enrichment complex, built around cascades of gas centrifuges used to enrich uranium. Parts of the enrichment infrastructure were underground and heavily physical protected.
- A facility like Natanz was expected to be difficult to reach remotely, so the operational environment relied heavily on **segmentation and air-gapping** to reduce exposure
 - weak or absent security measures were applied within the environment, most of the plant's protection was relied on physical isolation.
- But Stuxnet's designers planned for exactly that constraint: the malware was built to spread through infected removable media and then propagate locally once inside the environment, counting on the weakness of the cyber defenses once they managed to get inside.



Stuxnet in one minute: what happened

- The best-supported public reconstruction is that Stuxnet entered the restricted environment through **human-carried removable media**, most plausibly via a maintenance engineer sent by Siemens to update the systems, with legitimate access in the environment.
- Once inside, Stuxnet used multiple Windows zero-days (i.e., unknown) vulnerabilities, propagated across local systems, checked for specific Siemens Step7 and PLC conditions, and activated its payload only when the target matched the intended industrial configuration.
- Once the right environment was found, it modified PLC logic related to centrifuge operation.
- The malicious logic changed operating behavior in ways designed to place stress on the equipment rather than cause an immediate obvious failure.
- At the same time, Stuxnet replayed or presented misleading normal readings to operators, masking the abnormal process behavior.





Why Stuxnet matters strategically

Stuxnet matters because it demonstrates that cyber operations can combine:

- highly targeted intrusion
- deep ICS / process knowledge
- tailored payload engineering
- stealth and deception
- physical sabotage

It is also historically important because it showed that:

- air-gapped environments are not immune,
- IT compromise can become OT manipulation,
- software can produce strategic physical effects,
- cyber operations can support national strategic objectives.



Stuxnet through the Kill Chain: structural progression

Phase	What Happened	Defensive Interruption Point
Reconnaissance	Adversaries gathered intelligence on: the target environment, Siemens PLC families, process characteristics, centrifuge operating profiles.	Limit public exposure of technical details; control supply-chain leakage; insider threat monitoring.
Weaponization	Malware engineered with: multiple Windows zero-days vulnerabilities, and custom PLC payload targeting specific centrifuge speeds.	Vulnerability management; secure development lifecycle for ICS components.
Delivery	The malware entered the environment through infected removable media reaching an engineering workstation in an air-gapped setting.	Strict removable media controls, media scanning, device control, procedural barriers.



Stuxnet through the Kill Chain: structural progression

Phase	What Happened	Defensive Interruption Point
Exploitation	Windows vulnerabilities enabled code execution and propagation in the local environment.	Timely patching; endpoint detection systems.
Installation	Persistence was established on Windows systems, while malicious logic was injected into PLC-related components.	Application whitelisting; integrity monitoring; PLC firmware validation.
Command and Control	Malware propagated and infected all hosts to update PLC configuration.	Network segmentation; detection of manipulated configuration.
Actions on Objective	Malicious PLC logic altered centrifuge rotation speed while reporting fake normal readings to operators.	Independent safety monitoring systems; process anomaly detection; trusted validation of OT state; separation between operational control and operator view.

Stuxnet through ATT&CK: behavioral decomposition



Tactic	Technique	Procedure	Analytical value
Initial Access	Replication Through Removable Media	An infected USB drive was physically introduced into an engineering workstation inside the air-gapped.	Shows that air-gapping changes network exposure, not all access paths
Execution	Exploitation for Client Execution	Stuxnet used previously unknown Windows vulnerabilities (zero-days) to execute its code automatically when the USB was accessed.	User action and zero-days vulnerabilities logic combine to create execution
Persistence	Boot or Logon Autostart Execution	Stuxnet copied its files into Windows system directories and created registry entries so that it would start every time the system rebooted.	Infection survives reboot and maintains foothold



Stuxnet through ATT&CK: behavioral decomposition



Tactic	Technique	Procedure	Analytical value
Privilege Escalation	Exploitation for Privilege Escalation	It exploited Windows vulnerabilities to obtain SYSTEM-level privileges.	Full control over the infected machine increases stealth, persistence, and staging capacity
Lateral Movement	Exploitation of Remote Services	It spread to other computers using shared network folders and by exploiting a vulnerability in the Windows Print Spooler service.	The infection propagated inside the facility. Local compromise becomes facility-wide operational exposure
Defense Evasion	Rootkit	It installed a Windows rootkit to hide its files and processes, and hide the malicious PLC code while sending false normal readings to monitoring systems.	Defenders lose trustworthy visibility into both IT and OT layers



Stuxnet through ATT&CK: behavioral decomposition



Tactic	Technique	Procedure	Analytical value
Command and Control	Application Layer Protocol	When Internet connectivity was available, infected machines contacted external command-and-control servers via HTTP.	Partial external connectivity can still matter in environments thought to be restricted.
Impact	Modify Controller Logic	It modified Siemens PLC code controlling centrifuge rotation speeds, periodically changing speed patterns, in ways designed to induce physical degradation.	Impact in OT is not only data loss: it can be controlled physical damage



What this case teaches

Stuxnet teaches five enduring lessons:

1. Air-gapping reduces exposure but does not remove attack paths.
2. IT and OT security cannot be separated in modern industrial defense.
3. If telemetry is incomplete, visibility is structurally weak.
4. Behavioral monitoring is essential in industrial environments.
5. **Cyber operations** can produce **strategic** physical **effects**.